

ANALYSE DE RISQUES

EBIOS Risk Manager

Organisation : Microfinance (30 employés, 3 agences)

Février 2026

Atelier 1 — Cadrage et socle de sécurité

1.1 Présentation de l'organisation

La structure étudiée est un établissement de microfinance composé de 30 employés répartis sur 3 agences. Son activité principale repose sur l'octroi de microcrédits et la gestion de comptes pour des particuliers et des petites entreprises à faibles revenus. En tant qu'organisme financier, elle manipule des données à caractère personnel sensibles (DCP) ainsi que des données financières soumises aux obligations réglementaires en vigueur (RGPD, réglementations bancaires locales).

1.2 Périmètre de l'étude

L'analyse couvre l'ensemble du système d'information opérationnel de l'organisation, incluant :

- Les postes de travail des conseillers et du personnel administratif
- Les serveurs hébergeant les applications métiers et les bases de données clients
- Le réseau informatique inter-agences (LAN/WAN)
- La connexion Internet et les accès distants éventuels
- Le logiciel de gestion financière (core banking)

1.3 Missions et processus métiers essentiels

Processus	Description	Criticité
Gestion des comptes clients	Enregistrement, consultation et mise à jour des informations clients	Élevée
Octroi de microcrédits	Instruction des dossiers, décision d'octroi, suivi des remboursements	Élevée
Gestion des transactions financières	Traitement, validation et archivage des opérations	Critique

1.4 Biens essentiels

Les biens essentiels représentent les informations et services dont la compromission aurait un impact direct sur les missions de l'organisation.

Bien essentiel	Type	Impact si compromis
Données personnelles des clients	Confidentialité / Intégrité	Violation RGPD, atteinte à la réputation
Dossiers de crédit	Intégrité / Disponibilité	Fraude, perte financière
Transactions financières	Intégrité / Disponibilité	Perte financière directe, non-conformité
Informations internes (procédures, RH)	Confidentialité	Atteinte aux intérêts de l'entreprise

1.5 Biens supports

Les biens supports sont les composants techniques sur lesquels reposent les biens essentiels.

- Postes de travail (Windows) des employés des 3 agences
- Serveurs applicatifs et de base de données (hébergement interne ou externalisé)
- Infrastructure réseau inter-agences (switchs, routeurs, VPN)
- Connexion Internet (accès en ligne, e-mail)
- Logiciel de gestion financière (core banking)
- Équipements physiques (onduleurs, locaux serveurs)

1.6 Socle de sécurité existant

Avant d'identifier les risques résiduels, il convient de noter les mesures de sécurité déjà en place ou supposées dans une structure de cette taille :

- Antivirus sur les postes de travail
- Pare-feu périmétrique
- Sauvegarde des données (fréquence non précisée)
- Contrôle d'accès physique aux locaux

Ces mesures constituent un socle minimal mais insuffisant face aux menaces identifiées ci-après.

1.7 Définition d'une échelle de risque

Nous avons défini notre échelle de risque par rapport aux besoins de sécurité d'Essential Bank.

Echelle	Conséquences
Critique G4	Incapacité d'assurer tout ou une partie de son activité. Existence menacée.
Elevée G3	Forte dégradation des performances de l'activité. Fonctionnement très ralenti.
Moyen G2	Dégradation des performances sans réel impact sur la sécurité. Quelques difficultés.
Faible G1	Aucun impact opérationnel. Consommation des marges.

Atelier 2 — Sources de risques

L'atelier 2 d'EBIOS RM vise à identifier et caractériser les sources de risques (SR) susceptibles d'agir intentionnellement ou non contre les biens essentiels de l'organisation.

Source de risque	Catégorie	Motivation	Capacité estimée
Employé négligent	Interne / Non intentionnel	Erreur, méconnaissance	Faible (mais fréquent)
Employé malveillant	Interne / Intentionnel	Gain financier, vengeance	Moyenne (accès légitimes)
Cybercriminel externe	Externe / Intentionnel	Gain financier	Moyenne à élevée
Fraudeur / Escroc	Externe / Intentionnel	Gain financier (fraude crédit)	Faible à moyenne

2.2 Couplage Sources de risques / Objectifs visés (SR/OV)

Le tableau ci-dessous met en relation chaque source de risque avec les objectifs visés sur les biens essentiels de l'organisation (confidentialité, intégrité, disponibilité). Ce couplage SR/OV constitue le cœur de l'Atelier 2 d'EBIOS RM et permet d'orienter la construction des scénarios stratégiques de l'Atelier 3.

Source de risque	Objectif visé (OV)	Bien essentiel ciblé	Confidentialité	Intégrité	Disponibilité	Priorité
Cybercriminel externe	OV-1 — Exfiltration de données clients	Données personnelles clients / Transactions financières	• Oui	—	—	Élevée
Cybercriminel externe	OV-2 — Chiffrement / Sabotage SI	Serveurs / Transactions financières	—	—	• Oui	Élevée
Employé malveillant	OV-3 — Fraude / Altération dossiers crédit	Dossiers de crédit / Transactions financières	—	• Oui	—	Élevée
Employé négligent	OV-4 — Divulgence accidentelle / Erreur opérationnelle	Données clients / Informations internes	• Oui	—	—	Moyenne
Fraudeur / Escroc	OV-5 — Usurpation d'identité / Fraude crédit	Dossiers de crédit / Données clients	• Oui	• Oui	—	Moyenne

Lecture : • Oui indique que la propriété DIC (Confidentialité, Intégrité, Disponibilité) est directement visée par la source de risque. Les couplages SR/OV retenus sont ensuite développés sous forme de scénarios stratégiques en Atelier 3.

Atelier 3 — Scénarios stratégiques

L'atelier 3 construit des scénarios de haut niveau reliant les sources de risques aux biens essentiels via des chemins d'attaque plausibles (écosystème inclus).

3.1 Scénario SS-01 — Compromission par hameçonnage (Phishing)

Source de risque : Cybercriminel externe.

Bien essentiel ciblé : Données personnelles clients, transactions financières.

Chemin d'attaque : Un employé reçoit un courriel frauduleux imitant un prestataire ou une institution bancaire partenaire. En cliquant sur le lien et en saisissant ses identifiants, il offre un accès non autorisé au système d'information. L'attaquant peut alors exfiltrer des données ou réaliser des opérations frauduleuses.

Vraisemblance : Élevée — aucune formation anti-phishing identifiée, messagerie non filtrée.

3.2 Scénario SS-02 — Fraude interne sur les dossiers de crédit

Source de risque : Employé malveillant (conseiller ou gestionnaire).

Bien essentiel ciblé : Dossiers de crédit, transactions financières.

Chemin d'attaque : Un employé disposant d'un accès légitime au logiciel de gestion modifie les conditions d'un dossier (montant, remboursement) à son profit ou à celui d'un tiers complice. L'absence de ségrégation des tâches et de journalisation facilite cette action.

Vraisemblance : Moyenne — dépend du niveau de contrôle interne.

3.3 Scénario SS-03 — Indisponibilité du système d'information

Source de risque : Panne technique, sinistre physique, ransomware.

Bien essentiel ciblé : Disponibilité des services financiers.

Chemin d'attaque : Une panne matérielle du serveur central ou une infection par rançongiciel entraîne l'arrêt complet des applications métiers. Sans plan de continuité (PCA/PRA), l'activité des 3 agences est interrompue, occasionnant des pertes financières et une perte de confiance des clients.

Vraisemblance : Moyenne — infrastructure vieillissante et sauvegardes insuffisamment testées.

Atelier 4 — Scénarios opérationnels

L'atelier 4 affine les scénarios stratégiques en modes opératoires techniques détaillés, permettant d'estimer la vraisemblance et la gravité des attaques.

Réf.	Mode opératoire	Vraisemblance	Gravité	Niveau de risque
SO-01a	Phishing ciblé → vol d'identifiants → exfiltration de données clients	4 / Élevée	4 / Critique	Inacceptable
SO-02a	Accès non audité au core banking → modification dossier → virement frauduleux	3 / Moyenne	4 / Critique	Inacceptable

Réf.	Mode opératoire	Vraisemblance	Gravité	Niveau de risque
SO-03a	Infection ransomware via pièce jointe → chiffrement serveur → arrêt activité	3 / Moyenne	4 / Critique	Inacceptable
SO-03b	Panne matérielle serveur sans redondance → arrêt partiel des services	3 / Moyenne	3 / Élevée	Important
SO-04a	Vol de poste de travail en agence → accès aux données locales non chiffrées	2 / Faible	3 / Élevée	Modéré

Atelier 5 — Traitement du risque

L'atelier 5 définit les mesures de traitement permettant de ramener les risques à un niveau acceptable, en distinguant les mesures techniques, organisationnelles et physiques.

5.1 Mesures relatives au risque SO-01a (Phishing / Exfiltration)

- Déploiement d'un filtre anti-spam et anti-phishing sur la messagerie (ex. solution email gateway)
- Mise en place de l'authentification multifacteur (MFA) sur l'ensemble des accès applicatifs
- Programme de sensibilisation annuel obligatoire avec simulation de phishing
- Activation des journaux d'authentification et alertes en cas de connexion anormale

5.2 Mesures relatives au risque SO-02a (Fraude interne)

- Mise en place de la ségrégation des tâches : la saisie et la validation d'un dossier ne doivent pas être assurées par le même employé
- Journalisation complète des accès et modifications dans le logiciel de gestion (core banking)
- Mise en place d'audits internes trimestriels sur les opérations sensibles
- Revue régulière des droits d'accès (recertification semestrielle)

5.3 Mesures relatives aux risques SO-03a et SO-03b (Indisponibilité)

- Mise en place d'un Plan de Reprise d'Activité (PRA) documenté et testé annuellement
- Sauvegardes automatiques quotidiennes avec test de restauration mensuel (règle 3-2-1)
- Solution de redondance serveur (virtualisation ou hébergement cloud partiel)
- Déploiement d'un EDR (Endpoint Detection & Response) en remplacement du simple antivirus

5.4 Mesures transversales

- Mise en place d'une politique de sécurité des systèmes d'information (PSSI) formalisée
- Chiffrement des disques durs des postes de travail mobiles (BitLocker ou équivalent)
- Contrôle d'accès physique renforcé aux salles serveurs (badge + journal des entrées)
- Mise à jour mensuelle systématique des systèmes d'exploitation et logiciels

5.5 Synthèse du traitement des risques

Risque	Mesure principale	Stratégie	Risque résiduel	Acceptabilité
SO-01a	MFA + Sensibilisation + Email gateway	Réduction	Modéré	Acceptable
SO-02a	Ségrégation des tâches + Journalisation	Réduction	Faible	Acceptable
SO-03a	EDR + PRA + Sauvegardes testées	Réduction	Modéré	Acceptable
SO-03b	Redondance + PRA	Réduction	Faible	Acceptable
SO-04a	Chiffrement disques + Politique BYOD	Réduction	Faible	Acceptable

Conclusion

Cette analyse EBIOS Risk Manager appliquée à la microfinance met en évidence que même une organisation de taille modeste, manipulant des données financières et personnelles sensibles, est exposée à des risques cyber significatifs. Les trois scénarios principaux identifiés — le phishing, la fraude interne et l'indisponibilité du SI — présentent un niveau de risque initialement inacceptable, justifiant des mesures de traitement prioritaires.

Les mesures proposées sont dimensionnées pour s'adapter aux contraintes budgétaires d'une PME (30 employés) tout en répondant aux exigences de conformité réglementaire. Leur mise en oeuvre progressive, en priorisant l'authentification multifacteur, la ségrégation des tâches et le plan de reprise d'activité, permettrait de ramener l'ensemble des risques résiduels à un niveau acceptable.

La formalisation d'une PSSI et la sensibilisation régulière des employés constituent le socle indispensable sur lequel doit reposer toute démarche de sécurisation durable d'une structure financière, quelle que soit sa taille.